Dispensa Lezione 1: Setup dell'Ambiente e Primi Passi nel Penetration Testing

1. Obiettivi della lezione

Benvenuti alla parte operativa del corso di Vulnerability Assessment e Penetration Testing. Dopo aver visto le basi metodologiche e di networking, da oggi si passa alla pratica.
L'obiettivo di questa lezione è preparare la nostra postazione di lavoro, configurare un bersaglio locale sicuro e capire come collegarci alle piattaforme di addestramento online. L'approccio che seguiremo d'ora in poi si basa su una regola fondamentale: **usare i tool con consapevolezza**. Non lanceremo comandi in automatico senza capirne l'output, ma cercheremo di comprendere sempre come la nostra macchina interagisce con il bersaglio.

Durante questo percorso, il programma si concentrerà su tre aree principali:

- Attacchi alle applicazioni (Web, SMTP).
- Attacchi alle reti fisiche (arpspoofing, dnsspoofing).
- Software security (buffer overflow).

---

2. Checklist: Le basi necessarie

Per affrontare agevolmente queste ore di laboratorio, diamo per acquisite alcune competenze tecniche di base. Se vi sentite insicuri su alcuni punti, usate questa prima lezione per ripassarli:

- **Riga di comando Linux:** Sapersi muovere nel file system (cd, ls), leggere i file (cat, less), cercare informazioni specifiche (grep) e gestire i permessi base.
- **Reti TCP/IP:** Conoscere la differenza tra IP locale e pubblico, il concetto di porte logiche e i protocolli associati ai servizi più comuni (es. 21 per FTP, 22 per SSH, 80 per HTTP).
- **Nmap:** Conoscere la sintassi base per l'enumerazione della rete, in particolare i comandi:
    - nmap -sS: per una scansione TCP stealth.
    - nmap -sV: per interrogare le porte e scoprire la versione esatta dei servizi.

---

3. Il bersaglio locale: Installazione di Metasploitable 2

Perché ci serve

Per fare pratica con gli exploit in modo sicuro e legale, ci serve un bersaglio isolato. Non possiamo testare vulnerabilità su reti pubbliche o sulla rete dell'istituto. **Metasploitable 2** è una macchina virtuale Linux creata appositamente con difetti di configurazione e servizi vulnerabili, ideale per iniziare a lavorare in locale senza problemi di rete.

Setup su VirtualBox

1. **Scaricare i file:** Recuperate l'archivio ZIP di Metasploitable 2 (fornito dal docente) ed estraete il file interno con estensione .vmdk (il disco virtuale).
2. **Creare la VM:** Aprite VirtualBox, cliccate su "Nuova".
   - Nome: Metasploitable 2
   - Tipo: Linux / Versione: Ubuntu (64-bit)
   - RAM: 512 MB o 1 GB.
3. **Configurare il disco:** Scegliete "Usa un file di disco fisso virtuale esistente" e selezionate il file .vmdk estratto prima.
4. **Impostare la Rete (Importante):** Andate nelle Impostazioni della VM -> Rete. Impostate la scheda su **Rete Host-Only** (Solo host) oppure **Rete NAT**.
   - *Nota bene:* Non usate mai "Scheda con bridge", per evitare di esporre questa macchina vulnerabile sulla rete fisica in cui vi trovate.
5. **Avvio:** Accendete la VM. Le credenziali per il login sono msfadmin (sia come utente che come password). Digitate ip a per scoprire quale indirizzo IP le è stato assegnato: quello sarà il vostro target locale.

---

4. Connettersi ai laboratori remoti: VPN, HackTheBox e TryHackMe

Perché usare una VPN

Molte delle esercitazioni pratiche verranno svolte su piattaforme come **HackTheBox (HTB)** e **TryHackMe (THM)**, che mettono a disposizione macchine vulnerabili in cloud. Per permettere a Kali Linux di comunicare direttamente con questi bersagli, dobbiamo usare una VPN (Virtual Private Network) tramite OpenVPN. Questo ci assegnerà un indirizzo IP privato (sulla scheda di rete virtuale tun0) interno al laboratorio.

Come connettersi

1. **Registrazione:** Create un account gratuito su *tryhackme.com* e *app.hackthebox.com*.
2. **Scaricare la configurazione:** * Su THM: andate sul vostro profilo -> Access -> Download My Configuration File.
   - Su HTB: andate su Connect to HTB -> Starting Point -> OpenVPN -> Download VPN.
   - Otterrete un file .ovpn.
3. **Avviare la connessione:** Aprite il terminale su Kali Linux, andate nella cartella dove avete scaricato il file ed eseguite questo comando (vi chiederà la password di root):

Bash
sudo openvpn --config nome_del_file.ovpn

4. **Verifica:** Lasciate questo terminale aperto. Apritene un altro, digitate ip a e verificate di avere l'interfaccia tun0 attiva con un indirizzo IP assegnato.

---

5. Primi passi: Eseguire un attacco base

Per verificare che tutto sia configurato correttamente, completiamo il flusso di lavoro standard su una macchina bersaglio "Very Easy" di HackTheBox (sezione Starting Point).

Fase 1: Verifica di rete (Ping)

Una volta avviata la macchina bersaglio dalla piattaforma, vi verrà dato il suo indirizzo IP (es. 10.129.x.x). La primissima cosa da fare è verificare che la VPN stia ruotando correttamente il traffico.

- Comando: ping -c 4 <IP_BERSAGLIO>
- *Cosa fa:* Invia 4 pacchetti ICMP. Se ricevete risposta, siete in grado di comunicare con la macchina.

Fase 2: Scansione (Nmap)

Ora cerchiamo di capire quali servizi (e su quali porte) la macchina sta esponendo.

- Comando: nmap -sV -sC <IP_BERSAGLIO>
- *Cosa fa:* Il comando individua i servizi aperti, ne estrae la versione esatta (-sV) e lancia alcuni script di base (-sC) per controllare le configurazioni di default o le vulnerabilità più evidenti.

Fase 3: Accesso

Analizzando l'output di Nmap, capiremo come muoverci. Se notate, ad esempio, che il servizio Telnet (porta 23) o FTP (porta 21) è aperto e accetta login anonimi, potete provare a connettervi direttamente:

Bash
telnet <IP_BERSAGLIO>
oppure
ftp <IP_BERSAGLIO>

Una volta dentro il sistema, il vostro compito è esplorare le cartelle per trovare la "flag" (solitamente un file di testo contenente una stringa) che vi permetterà di convalidare l'attacco sulla piattaforma.

Appendice

A. Conoscenza base di Linux CLI

L'interfaccia a riga di comando (CLI) è fondamentale. Ecco i comandi essenziali da conoscere per muoversi nel sistema (ls, cd, grep, cat...):

- **ls**: Elenca i file e le directory. (Es. ls -la mostra anche i file nascosti e i permessi).
- **cd**: Cambia la directory corrente (Es. cd /var/www/html o cd .. per tornare indietro).
- **cat**: Legge e stampa a schermo l'intero contenuto di un file (Es. cat /etc/passwd).
- **grep**: Filtra l'output cercando una parola specifica (Es. cat file.txt | grep "admin").

B. Conoscenza base di networking

È richiesta una conoscenza base di networking, in particolare del protocollo TCP/IP, e l'utilizzo di strumenti diagnostici di rete come ss, netstat e iputils:

- **iputils (es. ping)**: Permette di verificare la raggiungibilità di un host inviando pacchetti ICMP.
- **netstat e ss**: Sono i comandi principali per analizzare le porte aperte e le connessioni attive sulla nostra macchina. Ad esempio, digitando ss -tulpn (o netstat -tulpn) potrete vedere esattamente quali servizi sono in ascolto sul vostro sistema, per evitare di esporre porte vulnerabili.

C. Conoscenza di ambiente a container (Docker)

Nel corso delle lezioni avremo bisogno di una conoscenza di ambiente a container tramite Docker. Docker ci permette di scaricare e avviare applicazioni (come siti web vulnerabili) in pochi secondi, senza dover configurare intere macchine virtuali. I comandi che useremo più spesso sono:

- **docker run <immagine>**: Scarica (se non è presente) e avvia un container.
- **docker ps**: Mostra la lista dei container attualmente attivi.
- **docker stop <id>**: Ferma un container in esecuzione.